Software Requirements Specification

for Nexus E-Commerce Platform

Version 1.0 approved

Prepared by: Platform Engineering Team

2026-10-01

Revision History

Version	Date	Author	Description
0.1	2026-08-12	Analyst	Initial draft of the requirement set
1.0	2026-10-01	Architect	Baseline approved by the change board

Contents

1 Introduction 3

1.1 Purpose 3

2 Overall Description 4

3 Specific Requirements 5

Appendix A: Glossary 9

1 Introduction

1.1 Purpose

This document specifies the functional requirements for the Nexus E-Commerce Platform API. It is intended for developers, testers and the change board.

1.2 Document Conventions

Requirement identifiers use the form REQ-NN. The word must indicates a mandatory requirement.

1.3 Definitions, Acronyms and Abbreviations

Term	Definition
JWT	JSON Web Token, a signed bearer credential
2FA	Two-factor authentication

1.4 References

IEEE Std 830-1998, Recommended Practice for Software Requirements Specifications.

2 Overall Description

The platform exposes a REST API consumed by the web storefront and mobile apps.

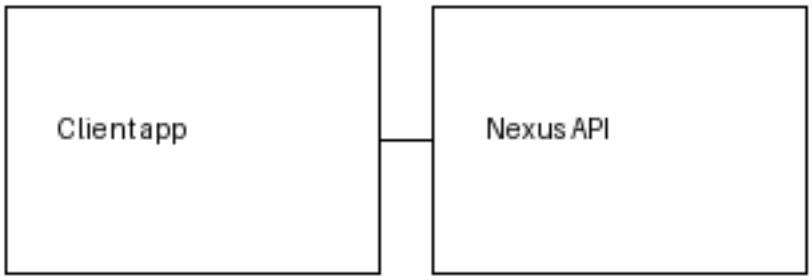


Figure 1: System context diagram

3 Specific Requirements

3.1 Core Functional Requirements

Table 2: Core functional requirements

ID	Title	Description	Priority
REQ-01	User Authentication & Session Management	The system must provide a secure user authentication mechanism that validates credentials against stored hashed passwords and issues a signed JWT access token with a configurable expiry time. All authenticated sessions must be uniquely identifiable via a session_id field returned in the authentication response, enabling session revocation and audit trail generation.	High
REQ-02	Product Catalogue Retrieval	The system must expose a paginated endpoint to retrieve the full product catalogue, supporting filtering by keyword, category, and price range. Each product record in the response must include the product_id, name, description, category, price, stock_quantity,	High

ID	Title	Description	Priority
		and at least one associated image_url. The endpoint must accept pagination parameters (page and page_size) to control result volume.	
REQ-03	Shopping Cart Management	The system must allow authenticated users to add, update quantity, and remove individual items from a persistent shopping cart. Every cart state response must include the full list of cart items with their item_id, product_id, quantity, unit_price, and a server-computed subtotal reflecting the current cart total. Cart state must persist across user sessions.	Medium
REQ-04	Refund Transaction Integrity	All refund transactions must include a unique, client-provided transaction_id field in the request body to enable idempotent processing and financial audit compliance. This transaction_id must also appear in the refund receipt returned in the API response, ensuring end-to-end traceability of every refund operation initiated by the client system.	High
REQ-05	Checkout & Order Placement	The checkout endpoint must accept a complete order payload including the user's cart contents, a validated shipping_address object, a selected delivery_method, and a payment_method_token. Upon successful order	High

ID	Title	Description	Priority
		placement, the API must return a unique order_id and an estimated_delivery_date. The endpoint must reject incomplete payloads with a structured validation error response.	
REQ-06	Payment Method Support	The system must support multiple payment methods including credit and debit card payments (via card_token), digital wallet payments through Apple Pay (via apple_pay_token) and Google Pay (via google_pay_token), and previously stored payment instruments (via saved_payment_id). The payment_type field must be explicitly declared in every payment processing request to identify the method being used.	Medium

3.2 Order Lifecycle Requirements

REQ-07: Order Status Tracking

The system must provide an authenticated endpoint that accepts an order_id and returns the real-time fulfilment status of that order. The status response must include a status_label field and an array of timeline_events, each with a stage name (order_placed, processing, dispatched, out_for_delivery, delivered) and its corresponding ISO 8601 timestamp. Orders that do not belong to the authenticated user must return a 403 Forbidden response.

REQ-08: User Profile Management

Authenticated users must be able to retrieve and update their profile information via dedicated GET and PUT endpoints. Updatable fields must include display_name, email, shipping_addresses (an array), and notification_preferences. Any request to change the email field must set an email_verification_pending flag in the response, indicating that a re-verification workflow has been triggered.

REQ-09: Two-Factor Authentication Enforcement

All high-value operations — defined as orders with a total value exceeding $500 or first-time registration of a new payment method — must require Two-Factor Authentication (2FA) verification before the operation is permitted to proceed. The system must expose a dedicated 2fa/challenge endpoint to issue a time-limited OTP, and a 2fa/verify endpoint to validate the user's submitted code before the primary operation is authorised.

REQ-10: Notification Subscription Management

The system must allow authenticated users to retrieve and modify their notification preferences via dedicated endpoints. Subscribable notification categories must include order_updates, promotional_offers, and security_alerts. Preference changes must be persisted immediately and honoured by all downstream messaging services. The response must confirm the updated preference state for each category.

Appendix A: Glossary

REQ-99: Example requirement format

Every requirement is written as an ID, a short title and a statement.